

INSTITUTO FEDERAL
Mato Grosso do Sul

Construção de Páginas Web III

Milena Alegre

INSTITUTO FEDERAL
Mato Grosso do Sul

Sessoes e Cookies

Parte 1: Teoria & OWASP

Middlewares Express: Interceptação de rotas.
OWASP Top 10: A01, A05 e A07 explicados.
Conceitos Clave: IDOR, RBAC e Menor Privilégio.
Segurança em Cookies: Flags de proteção HTTP.

Parte 2: Prática Passo a Passo

- **Filtros de Acesso:** Proteção de rotas privadas.
- **Controle RBAC:** Bloqueio por papéis de usuário.
- **Upload de Arquivos:** Integração com Multer.
- **Validação Rígida:** MIME types e renomeação.

INSTITUTO FEDERAL
Mato Grosso do Sul

O ciclo da sessao HTTP

01

Autenticação Inicial

Usuário envia credenciais válidas via POST no login.

02

Criação de Sessão

Servidor gera Session ID e armazena dados em memória.

03

Envio do Cookie

Navegador recebe Cookie com ID de sessão assinado.

04

Validação Contínua

Middleware valida o cookie a cada requisição restrita.

INSTITUTO FEDERAL
Mato Grosso do Sul

O ciclo da decisão da requisição

1

Requisição HTTP

Navegador solicita rota restrita.

2

Filtro (Middleware)

Inspeciona o Cookie da Sessão.

3A

Sessão Válida

Libera acesso à página solicitada.

3B

Sessão Ausente

Redireciona para /login (401).

INSTITUTO FEDERAL
Mato Grosso do Sul

Protecao

Autenticação Restrita

Validação contínua da sessão ativa em cada página privada.

Destruição Explícita

Encerramento total no servidor e limpeza do cookie no cliente.

Redirecionamento

Desvio automático de acessos anônimos diretamente ao login.

INSTITUTO FEDERAL
Mato Grosso do Sul

Protecao

Boas Práticas na Gestão de Sessões

Regeneração do ID

Regerar o Session ID logo após o login para evitar ataques de fixação de sessão.

Timeout de Inatividade

Expirar sessões inativas após determinado tempo (ex: 15 minutos).



INSTITUTO FEDERAL
Mato Grosso do Sul

O Risco do Acesso Direto por URL

Cenário Sem Filtro

Sem middleware de verificação, qualquer visitante pode digitar a URL diretamente:

```
GET http://localhost:3000/admin/painel
```

O servidor processa a requisição sem checar se há usuário autenticado.

Cenário Com Filtro (Ideal)

O Middleware intercepta a requisição antes de entregar os dados:

```
Sessão inválida → Redirecionar /login (401)
```

Garantia de segurança centralizada em todas as rotas privadas.



INSTITUTO FEDERAL
Mato Grosso do Sul

Middleware

O middleware é uma camada de software que atua como uma ponte ou um "tradutor" permitindo que diferentes aplicativos, sistemas e bancos de dados se comuniquem entre si de forma eficiente.

O que ele faz?
Conecta sistemas: Une tecnologias diferentes que não foram feitas para conversar diretamente.

Funciona como uma "cola": Fica no meio do caminho (entre o sistema operacional e as aplicações) gerenciando dados, mensagens e requisições.

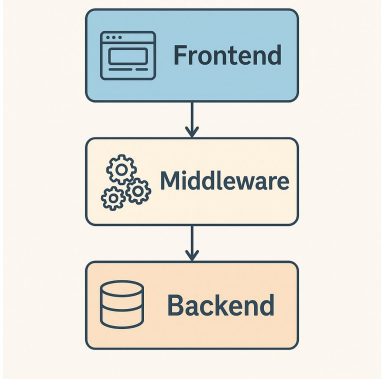
Facilita o trabalho: Evita que programadores precisem criar códigos complexos do zero para integrar sistemas

INSTITUTO FEDERAL
Mato Grosso do Sul

Middleware

Imagine que você faz uma compra em um site de loja virtual:

1. O site (**frontend**) recebe seu pedido de pagamento.
2. O **middleware** intercepta essa solicitação, verifica se você está logado com segurança e traduz os dados para o sistema do banco.
3. O servidor do banco (**backend**) processa o pagamento e devolve a resposta pelo middleware, que avisa o site se deu tudo certo



INSTITUTO FEDERAL
Mato Grosso do Sul

Middleware

Função interceptadora executada no pipeline entre a requisição e a resposta final.

Interceptação

Examina dados de requisição, cookies e cabeçalhos HTTP.

Tomada de Decisão

Bloqueia o acesso imediatamente ou autoriza o fluxo.

Encaminhamento

Chama next() para passar o controle à próxima função.

INSTITUTO FEDERAL
Mato Grosso do Sul

Middleware

req (Request): Acessa req.session, parâmetros e cookies.

res (Response): Envia respostas HTTP ou faz redirecionamentos.

next (Function): Gatilho essencial para liberar a execução da rota.

INSTITUTO FEDERAL
Mato Grosso do Sul

Http de Interceptacao

1. Cliente envia GET /dashboard	Header Cookie traz connect.sid
2. express-session recupera req.session	Busca dados no Session Store
3. Middleware checarAutenticacao executa	Avalia se req.session.user existe
4. Decisão: next() ou redirect('/login')	Entrega dashboard ou código 401/403

INSTITUTO FEDERAL
Mato Grosso do Sul

OWASP TOP 10

Open Web Application Security Project: Padrão global de conscientização sobre riscos em softwares web.

Referência Mundial

Lista atualizada periodicamente com base em dados de ataques globais reais.

Foco em Desenvolvedores

Fornece diretrizes para escrever código seguro desde a concepção do backend.



INSTITUTO FEDERAL
Mato Grosso do Sul

OWASP10

OWASP A01:2021 – Broken Access Control

Falha em impor restrições adequadas sobre o que usuários autenticados ou anônimos podem fazer.

Bypass de URL

Acessar páginas administrativas sem permissão apenas digitando o link.

Manipulação de Parâmetros

Alterar IDs na URL para visualizar dados pertencentes a outros usuários.

Métodos HTTP Elevados

Usar POST/DELETE em APIs sem validação de papéis de acesso no backend.

INSTITUTO FEDERAL
Mato Grosso do Sul

OWASP10

CÓDIGO VULNERÁVEL

```
app.get('/api/relatorio', (req, res) => { // Erro:
Entrega dados sigilosos // sem checar se há usuário
logado! res.json(dadosFinanceiros); });
```

CÓDIGO CORRIGIDO

```
app.get('/api/relatorio',  checarAuth, (req, res) => {
// Sucesso: Middleware checarAuth // valida req.session
antes de rodar res.json(dadosFinanceiros); });
```

INSTITUTO FEDERAL
Mato Grosso do Sul

OWASP10

OWASP A07:2021 – Authentication Failures

Falhas na confirmação da identidade do usuário e gerenciamento de sessões.

Session Fixation

Manter o mesmo ID de sessão antes e depois do login permite sequestro de conta.

Logout Incompleto

Destruir a sessão no servidor mas esquecer de apagar o Cookie no navegador.

INSTITUTO FEDERAL
Mato Grosso do Sul

OWASP10

OWASP A05:2021 – Security Misconfiguration

Configuração incorreta ou insegura nos cookies de sessão da aplicação.

Cookie Sem HttpOnly

Permite que scripts maliciosos liam o cookie via document.cookie (XSS).

Cookie Sem SameSite

Torna a aplicação vulnerável a requisições forjadas entre sites (CSRF).

INSTITUTO FEDERAL
Mato Grosso do Sul

OWASP10

O que é IDOR (Insecure Direct Object Reference)?

Ocorre quando a aplicação expõe referências a objetos internos sem validar a posse.

Exemplo de Ataque IDOR

Usuário 105 altera a URL para GET /api/user/106 e acessa os dados do Usuário 106 porque o backend não confirmou se o token da sessão pertencia ao ID 106.

INSTITUTO FEDERAL
Mato Grosso do Sul

OWASP10

ERRADO: Confia na URL

```
app.get('/perfil/:id', (req, res) => { const id =
req.params.id; // Busca direto no banco sem checar const
user = db.find(id); res.json(user); });
```

CORRETO: Usa a Sessão

```
app.get('/perfil', checarAuth, (req, res) => { // Extrai
o ID da sessão autenticada! const id =
req.session.user.id; const user = db.find(id);
res.json(user); });
```

INSTITUTO FEDERAL
Mato Grosso do Sul

Privilege Escalation

ESCALAÇÃO VERTICAL

Usuário → Administrador

Um usuário comum obtém acesso a funções executivas restritas da aplicação.

ESCALAÇÃO HORIZONTAL

Usuário A → Usuário B

Um usuário acessa ou modifica recursos de outro usuário com o mesmo nível de permissão.

Princípio do Menor Privilégio: Principle of Least Privilege: Dar permissão apenas ao estritamente necessário.

Restrição Total

Nenhuma conta deve possuir mais acessos do que os requeridos por sua função diária.

Isolamento no Middleware

Validar permissões em cada camada de rota antes de consultar o banco de dados.

INSTITUTO FEDERAL
Mato Grosso do Sul

Princípio do Bloqueio por padrão

Deny by Default / Fail-Safe Defaults: Negação implícita de todas as rotas.

Regra de Ouro da Segurança

Todas as rotas da aplicação devem ser tratadas como restritas por padrão. Somente rotas explicitamente públicas (como /login e /cadastro) devem ser liberadas sem autenticação.

INSTITUTO FEDERAL
Mato Grosso do Sul

RBAC (Role-Based Access Control)

Modelo de controle de acesso baseado em papéis de usuário atribuidor.

ROLE: 'USER'

Usuário Comum

Acessa apenas seu próprio perfil e dados vinculados à sua conta.

ROLE: 'ADMIN'

Administrador

Acessa relatórios gerais, gerenciamento de usuários e configurações.

INSTITUTO FEDERAL
Mato Grosso do Sul

RBAC (Role-Based Access Control)

```
const express = require('express');
const app = express();

const user = { name: 'Milena', role: 'admin'};
//middleware simples
function eAdmin(req, res, next){
    if(user.role == 'admin'){
        return next();//papel certo = libera acesso
    }
    return res.status(403).send('Acesso negado!')
}

//rotas
app.get('/publico', (req, res)=> res.send('Acesso liberado para a todos'));
app.get('/admin', eAdmin, (req, res) => res.send('Area restrita [admin]'));

app.listen(3000, () => {
  console.log('Servidor rodando em http://localhost:3000');
});
```

INSTITUTO FEDERAL
Mato Grosso do Sul

Logout -sessao

1. Destruir no Servidor
req.session.destroy()

Elimina o objeto armazenado na memória ou Session Store.

2. Limpar Cookie no Cliente
res.clearCookie('connect.sid')

Instrui o navegador a remover o cookie ativamente.

INSTITUTO FEDERAL
Mato Grosso do Sul

Cookies

HTTPONLY

Impede acesso via scripts JS no navegador. Protege contra roubo por XSS.

SAMESITE: 'LAX'

Evita envio do cookie em requisições de sites terceiros. Protege contra CSRF.

SECURE

Exige conexão criptografada HTTPS para trafegar o cookie.

INSTITUTO FEDERAL
Mato Grosso do Sul

Testar

No moodle tem modulo Guias > Estrutura

milena.alegre@ifms.edu.br

INSTITUTO FEDERAL
Mato Grosso do Sul